CCDC reference sheet (printed notes are allowed; your own packet overrides this)

Rules to remember

Printed notes	allowed. No phones, USB or other electronics
Root / Administrator	change any time, no ticket
Accounts services use	Password Change Request ticket FIRST
Public services	no source filtering. May block a single attacking IP, never a subnet
Do not change	hostnames, usernames, internal IPs, unless an inject says to
Never	scan or touch another team, Red, White or global assets
Say	your team number, never your school
Injects	PDF unless told otherwise. Late usually means zero
Incident report	what happened, source and destination IPs, timeline, cracked passwords, what was affected, fix

Editors

nano FILE	^O Enter saves, ^X exits, ^K cuts a line
vi FILE	i to type, Esc to stop
:wq	vi: save and quit
:q!	vi: quit, discard
dd / u / /word	vi: delete line / undo / search

Ports

22	SSH
25	SMTP
53	DNS (udp and tcp)
80 / 443	HTTP / HTTPS
110	POP3
123	NTP
445	SMB
3306	MySQL / MariaDB
3389	RDP
5985	WinRM

Linux: look

cat /etc/issue	which OS
ss -tulpn	what is listening
ps aux	what is running
who ; last	who is on, who was
grep ":x:0:" /etc/passwd	extra root accounts
ls /etc/cron.d ; crontab -l	scheduled jobs
cat /root/.ssh/authorized_keys	keys that log in as root
ls /etc/sudoers.d	sudo rules
find /var/www -name "*.php"	look for web shells
grep Accepted /var/log/auth.log	logins (Debian, Ubuntu)
grep Accepted /var/log/secure	logins (CentOS, Fedora)

Linux: change

passwd root	change a password
cp -a /var/www/html /root/www.bak	back up first
userdel NAME	delete an account
rm FILE	delete, after reading it
sed -i 's/old/new/' FILE	edit a file
service NAME status|restart	old systems (Ubuntu 14)
systemctl status|restart NAME	newer systems
curl http://localhost/	test the website

Harder Linux backdoors

lsattr FILE ; chattr -i FILE	cannot delete as root? immutable flag
cat /etc/rc.local	boot script
systemctl list-timers	the newer cron
cat /etc/ld.so.preload	should not exist
cat /root/.bashrc	aliases, login commands
find / -perm -4000	SUID programs
ss -antp ; who	live connections, sessions
pkill -9 -t pts/N	kick a session, AFTER changing the password
bash -i >& /dev/tcp/	reverse shell
curl ... | bash	download and run

Old systems

/etc/apt/sources.list	Debian 8: use archive.debian.org
apt-get -o Acquire::Check-Valid-Until=false update	accept the expired date
/etc/yum.repos.d/CentOS-Base.repo	#mirrorlist, baseurl=http://vault.centos.org
Fedora 21	archives.fedoraproject.org/pub/archive/...
No connection?	outbound blocked on the Palo Alto?

Host firewalls: allow first, then block

iptables -L -n	list
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT	allow replies
iptables -A INPUT -p tcp --dport 80 -j ACCEPT	allow a port
iptables -P INPUT DROP	then drop the rest
firewall-cmd --list-all	list
firewall-cmd --permanent --add-service=http	save a rule
firewall-cmd --permanent --remove-port=3306/tcp	save a removal
firewall-cmd --reload	make saved rules live
ufw allow 80/tcp ; ufw enable	Ubuntu

Palo Alto CLI

show interface all	zones
show running nat-policy	public addresses
show running security-policy	live rules
configure	enter config mode
set rulebase security rules NAME from Core to ZONE source any destination PUBLIC-IP application APP service application-default action allow	add a rule
application [web-browsing ssl]	a list uses spaces and brackets
delete rulebase security rules NAME	remove
move rulebase security rules NAME top	reorder
set mgt-config users admin password	admin password, needs commit
commit	apply. Takes a while
exit ; show jobs all	watch it: FIN and OK
test security-policy-match from Core to ZONE source 8.8.8.8 destination PUBLIC-IP destination-port 80 protocol 6	what would happen
show log traffic last 50 direction equal backward	recent traffic
set rulebase security rules X from Core to any source IP destination any application any service any action deny	block ONE address, then move it top
Rule destination	PUBLIC address, zone AFTER NAT
Apps	web-browsing ssl smtp pop3 dns ping

Windows / AD (PowerShell)

`Get-ADGroupMember 'Domain Admins'`	who runs the domain
`Get-LocalGroupMember Administrators`	local admins
`Get-ADUser -Filter *`	all accounts
`Set-ADAccountPassword -Identity NAME -Reset -NewPassword (ConvertTo-SecureString 'PW' -AsPlainText -Force)`	change an AD password
`Remove-ADGroupMember -Identity 'Domain Admins' -Members NAME`	remove rights
`Disable-ADAccount -Identity NAME`	disable
`Disable-LocalUser -Name NAME`	disable local
`Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force`	SMBv1 off
`Stop-Service Spooler -Force`	stop
`Set-Service Spooler -StartupType Disabled`	keep it off
`Get-ScheduledTask`	look for persistence
`Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} -MaxEvents 5`	read events
`netstat -ano ; Get-Process`	connections, PIDs
`reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run`	startup
`setspn -Q */*`	Kerberoast targets
`Reset krbtgt twice`	kills forged tickets
`New-NetFirewallRule -DisplayName X -Direction Inbound -LocalPort N -Protocol TCP -Action Block`	block a port

Splunk

`sourcetype=access_combined | stats count by src_ip | sort -count`	busiest web clients
`sourcetype=linux_secure "Failed password" | stats count by src_ip`	guessing attempts
`sourcetype=linux_secure "Accepted password"`	logins that worked
`4624 / 4625`	Windows login worked / failed
`4720 / 4728`	account created / added to a group
`4688 / 7045 / 4698 / 1102`	process / service / task / log cleared
`splunk enable listen 9997`	on the server
`splunk add forward-server IP:9997 ; add monitor FILE`	on each machine

Something is red

1	Machine on?
2	Service running?
3	Listening? ss -tulpn
4	Works from inside? curl
5	Host firewall?
6	Palo Alto? test security-policy-match
7	What changed? Ask the team
`Last resort`	Tech Support ticket: costs points, holes come back